

You are a SOC Analyst preparing the final investigation summary. Using all previous findings: • Authentication events • Sysmon events • Network activity • MITRE ATT&CK Mapping • Sigma Rules • Incident Report • AI Security Assessment Prepare a Final Investigation Summary. Include: 1. Executive Summary 2. Attack Timeline 3. Indicators of Compromise 4. MITRE ATT&CK Summary 5. Detection Opportunities 6. Containment Actions 7. Lessons Learned 8. SOC Recommendations Only use confirmed evidence and clearly identify any assumptions.

Final SOC Investigation Summary

Incident ID: SOC-IR-2026-0703-001
Prepared By: Tier-1 SOC Analyst
Date: July 3, 2026
Incident Status: Escalated to Tier-2 / Incident Response
Overall Severity: Critical

1. Executive Summary

A review of Windows Security and Sysmon telemetry identified a sequence of events consistent with a suspected compromise of a privileged account.

The investigation identified:

- Multiple failed authentication attempts against the **Administrator** account.
- A successful Administrator login from the same source IP shortly afterward.
- Execution of an encoded PowerShell command.
- An outbound HTTPS connection initiated by PowerShell to an external IP address.

These events, when correlated, indicate suspicious post-authentication activity that requires immediate containment and further forensic investigation.

Additionally, a separate security assessment identified an operational security issue in which internal security logs containing usernames, internal IP addresses, and an API key were copied into a public AI chatbot. This represents a **separate security incident** involving potential sensitive data exposure and should be handled independently from the suspected host compromise.

2. Attack Timeline

Time	Event	Status
T0	Multiple failed Windows Event ID 4625 authentication attempts against Administrator from 192.168.10.25	Confirmed
T0 + 5 min	Windows Event ID 4624 successful Administrator login from the same IP	Confirmed
Immediately After	Sysmon Event ID 1 recorded powershell.exe executing an encoded command	Confirmed

Time	Event	Status
Shortly After	Sysmon Event ID 3 recorded outbound HTTPS communication from PowerShell to 203.0.113.50:443	Confirmed
Following Investigation	Incident escalated for containment and forensic analysis	Recommended Response

3. Indicators of Compromise (IoCs)

Confirmed IoCs

Network Indicators

Indicator	Description
-----------	-------------

192.168.10.25	Source IP used for authentication attempts
203.0.113.50	External destination contacted by PowerShell
TCP Port 443	HTTPS communication

Host Indicators

Indicator	Description
-----------	-------------

powershell.exe	Suspicious process execution
-EncodedCommand / -enc	Encoded PowerShell command-line parameter
Administrator account	Targeted privileged account

Windows Events

Event ID	Description
----------	-------------

4625	Failed logon
4624	Successful logon

Sysmon Events

Event ID	Description
----------	-------------

1	Process creation
3	Network connection

4. MITRE ATT&CK Summary

Tactic	Technique ID	Technique	Evidence
Credential Access	T1110	Brute Force	Multiple failed logins
Defense Evasion / Initial Access	T1078	Valid Accounts	Successful Administrator authentication
Execution	T1059.001	Command and Scripting Interpreter: PowerShell	Encoded PowerShell execution
Defense Evasion	T1027	Obfuscated Files or Information	Encoded command usage
Command and Control	T1071.001	Application Layer Protocol: Web Protocols	HTTPS connection from PowerShell

Not Confirmed

No evidence was found for:

- Persistence
- Lateral Movement
- Privilege Escalation
- Data Exfiltration
- Impact (e.g., ransomware or destructive actions)

These activities remain **unconfirmed** based on the available logs.

5. Detection Opportunities

The investigation identified several opportunities to strengthen detection capabilities.

Authentication Monitoring

- Detect repeated failed logons (Windows Event ID 4625).
- Alert on successful privileged logons following multiple failures.
- Monitor abnormal Administrator account usage.
- Correlate authentication failures and successes by source IP and timeframe.

Process Monitoring

- Detect PowerShell executions using -EncodedCommand or -enc.
- Monitor PowerShell launched by unusual parent processes.
- Enable PowerShell Script Block Logging and Module Logging.

Network Monitoring

- Alert on PowerShell initiating outbound network connections.

- Monitor outbound HTTPS traffic to unknown or low-reputation destinations.
- Identify beaconing patterns through repeated network connections.

Persistence Monitoring

Although no persistence was observed, monitor for:

- Registry Run Key modifications (Sysmon Event ID 13)
- Scheduled Task creation
- Service installation
- Startup folder changes

DNS Monitoring

Monitor Sysmon Event ID 22 for:

- Repeated DNS queries
- Suspicious domains
- PowerShell-initiated DNS activity

Sigma Rules Developed

The following Sigma detections were prepared during the investigation:

- Windows Event ID 4625 – Failed Logons
 - Sysmon Event ID 1 – Encoded PowerShell Execution
 - Sysmon Event ID 13 – Registry Run Key Modification
 - Sysmon Event ID 22 – Suspicious DNS Queries
-

6. Containment Actions

Immediate Actions

- Isolate the affected endpoint from the network.
- Reset or disable the Administrator account if compromise is suspected.
- Rotate privileged credentials.
- Block communication with 203.0.113.50.
- Preserve forensic evidence (memory, processes, network connections, and logs).
- Escalate the incident to the Tier-2 SOC or Incident Response team.

AI Security Incident

For the separate AI-related security incident:

- Rotate the exposed API key immediately.
- Review exactly what data was shared.

- Notify the appropriate security and data owners.
 - Monitor for unauthorized API usage.
 - Assess compliance and reporting obligations according to organizational policy.
-

7. Lessons Learned

From the Security Investigation

- Correlating authentication, process creation, and network telemetry provides stronger detection confidence than analyzing events individually.
- Encoded PowerShell execution is a high-value indicator that warrants prompt investigation.
- Privileged account activity should receive enhanced monitoring and alerting.

From the AI Security Assessment

- Public AI tools should not be used to process sensitive organizational information unless explicitly approved.
 - API keys, credentials, internal IP addresses, and identifiable user information should be removed or anonymized before seeking AI assistance.
 - AI-generated recommendations should support, not replace, analyst validation and established investigation procedures.
-

8. SOC Recommendations

Incident Response

- Complete forensic analysis of the affected endpoint.
- Decode and analyze the PowerShell command.
- Investigate the reputation and purpose of 203.0.113.50.
- Conduct organization-wide threat hunting for similar indicators.
- Verify that no additional privileged accounts were affected.

Detection Engineering

- Deploy the developed Sigma rules.
- Correlate authentication, PowerShell, and network events in the SIEM.
- Enable comprehensive PowerShell logging.
- Integrate threat intelligence for IP and domain reputation.
- Continuously tune detections to reduce false positives.

Security Hardening

- Enforce Multi-Factor Authentication (MFA) for privileged accounts where feasible.

- Restrict or disable routine use of the built-in Administrator account.
- Apply least-privilege principles for administrative access.
- Review account lockout thresholds to reduce the risk of brute-force attacks.

AI Governance

- Establish an approved enterprise AI solution for security investigations.
 - Implement Data Loss Prevention (DLP) controls to detect sensitive information submitted to external AI services.
 - Deploy secret-scanning tools to identify exposed API keys and credentials before data leaves the organization.
 - Publish and enforce an AI Acceptable Use Policy.
 - Provide regular training on secure AI usage for SOC personnel.
-

Confirmed Evidence vs. Assumptions

Confirmed Evidence

- Multiple failed Administrator logon attempts (Windows Event ID 4625).
- Successful Administrator logon from the same source IP (Windows Event ID 4624).
- Execution of powershell.exe with an encoded command (Sysmon Event ID 1).
- Outbound HTTPS connection from PowerShell to 203.0.113.50:443 (Sysmon Event ID 3).
- Internal security logs containing usernames, internal IP addresses, and an API key were copied into a public AI chatbot.

Investigative Assumptions (Not Confirmed)

- The successful authentication resulted from credential compromise rather than legitimate use.
- The encoded PowerShell command executed malicious functionality.
- The HTTPS connection represented Command-and-Control (C2), payload retrieval, or data exfiltration.
- The attacker established persistence or performed lateral movement.
- The exposed AI-submitted data was accessed or misused by unauthorized parties.

Final Analyst Assessment

The available evidence supports a **high-confidence suspected host compromise** involving a privileged account and suspicious PowerShell activity. Although the attacker's ultimate objective cannot be confirmed from the available logs, the event sequence justifies a **Critical** severity rating and immediate containment.

Separately, the AI-related data handling issue constitutes a **High** severity information security incident due to the confirmed exposure of sensitive internal data and an API key to a

public AI service. Both incidents require follow-up, but they should be tracked and managed as distinct security events because they involve different risk domains and remediation activities.